

HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG

HOÀNG XUÂN DẬU

GIÁO TRÌNH
CƠ SỞ AN TOÀN THÔNG TIN

HÀ NỘI 2018

MỤC LỤC

MỤC LỤC	1
DANH MỤC CÁC HÌNH	5
DANH MỤC CÁC THUẬT NGỮ TIẾNG ANH VÀ VIẾT TẮT	9
MỞ ĐẦU	11
CHƯƠNG 1. TỔNG QUAN VỀ AN TOÀN THÔNG TIN	13
1.1. KHÁI QUÁT VỀ AN TOÀN THÔNG TIN	13
1.1.1. Một số khái niệm trong an toàn thông tin.....	13
1.1.2. Sự cần thiết của an toàn thông tin.....	15
1.2. CÁC YÊU CẦU ĐẢM BẢO ATTT VÀ HTTT	17
1.2.1. Bí mật	17
1.2.2. Toàn vẹn	18
1.2.3. Sẵn dùng	18
1.3. CÁC THÀNH PHẦN CỦA AN TOÀN THÔNG TIN	19
1.3.2. An toàn máy tính và dữ liệu	20
1.3.3. An ninh mạng	20
1.3.4. Quản lý an toàn thông tin	20
1.3.5. Chính sách an toàn thông tin	21
1.4. CÁC MỐI ĐE DỌA VÀ NGUY CƠ TRONG CÁC VÙNG HẠ TẦNG CNTT	22
1.4.1. Bảy vùng trong cơ sở hạ tầng CNTT.....	22
1.4.2. Các mối đe dọa và nguy cơ trong các vùng hạ tầng CNTT.....	23
1.5. MÔ HÌNH TỔNG QUÁT ĐẢM BẢO ATTT VÀ HỆ THỐNG THÔNG TIN.....	24
1.5.1. Nguyên tắc đảm bảo an toàn thông tin, hệ thống và mạng.....	24
1.5.2. Mô hình tổng quát đảm bảo an toàn thông tin và hệ thống thông tin.....	24
1.6. CÂU HỎI ÔN TẬP	26
CHƯƠNG 2. LỖ HỔNG BẢO MẬT VÀ ĐIỂM YẾU HỆ THỐNG	27
2.1. TỔNG QUAN VỀ LỖ HỔNG BẢO MẬT VÀ ĐIỂM YẾU HỆ THỐNG	27
2.1.1. Khái quát về điểm yếu hệ thống và lỗ hổng bảo mật	27
2.1.2. Một số thống kê về lỗ hổng bảo mật	29
2.2. CÁC DẠNG LỖ HỔNG TRONG HỆ ĐIỀU HÀNH VÀ PHẦN MỀM ỨNG DỤNG	31
2.2.1. Lỗi tràn bộ đệm	32
2.2.2. Lỗi không kiểm tra đầu vào.....	37

2.2.3. Các vấn đề với điều khiển truy nhập	39
2.2.4. Các điểm yếu trong xác thực, trao quyền	40
2.2.5. Các điểm yếu trong các hệ mật mã.....	40
2.2.6. Các lỗ hổng bảo mật khác.....	41
2.3. QUẢN LÝ, KHẮC PHỤC CÁC LỖ HỒNG BẢO MẬT VÀ TĂNG CƯỜNG KHẢ NẲNG ĐỀ KHÁNG CHO HỆ THỐNG	41
2.3.1. Nguyên tắc chung	41
2.3.2. Các biện pháp cụ thể.....	42
2.4. GIỚI THIỆU MỘT SỐ CÔNG CỤ RÀ QUÉT ĐIỂM YẾU VÀ LỖ HỒNG BẢO MẬT	43
2.4.1. Công cụ rà quét lỗ hổng bảo mật hệ thống.....	43
2.4.2. Công cụ rà quét lỗ hổng ứng dụng web.....	44
2.5. CÂU HỎI ÔN TẬP	45
CHƯƠNG 3. CÁC DẠNG TẤN CÔNG VÀ CÁC PHẦN MỀM ĐỘC HẠI	46
3.1. KHÁI QUÁT VỀ MỐI ĐE DỌA VÀ TẤN CÔNG.....	46
3.1.1. Mối đe dọa.....	46
3.1.2. Tấn công	46
3.2. CÁC CÔNG CỤ HỖ TRỢ TẤN CÔNG.....	47
3.2.1. Công cụ quét cổng dịch vụ	47
3.2.2. Công cụ nghe lén	48
3.2.3. Công cụ ghi phím gõ	49
3.3. CÁC DẠNG TẤN CÔNG THƯỜNG GẶP.....	50
3.3.1. Tấn công vào mật khẩu.....	50
3.3.2. Tấn công bằng mã độc.....	51
3.3.3. Tấn công từ chối dịch vụ và tấn công từ chối dịch vụ phân tán.....	56
3.3.4. Tấn công giả mạo địa chỉ.....	62
3.3.5. Tấn công nghe lén.....	62
3.3.6. Tấn công kiểu người đứng giữa.....	63
3.3.7. Tấn công bằng bom thư và thư rác	64
3.3.8. Tấn công sử dụng các kỹ thuật xã hội	65
3.3.9. Tấn công pharming.....	67
3.4. CÁC DẠNG PHẦN MỀM ĐỘC HẠI	68
3.4.1. Giới thiệu	68
3.4.2. Bom lô gic	69
3.4.3. Trojan Horses	70

3.4.4. Cửa hậu.....	70
3.4.5. Vi rút.....	71
3.4.6. Sâu	73
3.4.7. Zombies	74
3.4.8. Rootkits.....	75
3.4.9. Adware và Spyware.....	75
3.4.10. Phòng chống phần mềm độc hại.....	76
3.5. CÂU HỎI ÔN TẬP	78
CHƯƠNG 4. ĐẢM BẢO AN TOÀN THÔNG TIN DỰA TRÊN MÃ HÓA.....	79
4.1. KHÁI QUÁT VỀ MÃ HÓA THÔNG TIN VÀ ỨNG DỤNG.....	79
4.1.1. Các khái niệm cơ bản	79
4.1.2. Các thành phần của một hệ mã hóa	82
4.1.3. Mã hóa dòng và mã hóa khối	82
4.1.4. Sơ lược lịch sử mật mã	83
4.1.5. Ứng dụng của mã hóa.....	84
4.2. CÁC PHƯƠNG PHÁP MÃ HÓA.....	84
4.2.1. Phương pháp thay thế	84
4.2.2. Phương pháp hoán vị	85
4.2.3. Phương pháp XOR	86
4.2.4. Phương pháp Vernam	86
4.2.5. Phương pháp sách hoặc khóa chạy.....	87
4.2.6. Phương pháp hàm băm	87
4.3. CÁC GIẢI THUẬT MÃ HÓA.....	87
4.3.1. Các giải thuật mã hóa khóa đối xứng	87
4.3.2. Các giải thuật mã hóa khóa bất đối xứng	96
4.4. Các hàm băm	99
4.4.1. Khái quát về hàm băm	99
4.4.2. Một số hàm băm thông dụng	102
4.5. CÂU HỎI ÔN TẬP	104
CHƯƠNG 5. CÁC KỸ THUẬT VÀ CÔNG NGHỆ ĐẢM BẢO AN TOÀN THÔNG TIN	105
5.1. ĐIỀU KHIỂN TRUY NHẬP	105
5.1.1. Khái niệm điều khiển truy nhập	105
5.1.2. Các biện pháp điều khiển truy nhập	105

5.1.3. Một số công nghệ điều khiển truy nhập	110
5.2. TƯỜNG LỬA.....	115
5.2.1. Giới thiệu.....	115
5.2.2. Các loại tường lửa	117
5.2.3. Các kỹ thuật kiểm soát truy nhập	119
5.2.4. Các hạn chế của tường lửa.....	119
5.3. CÁC HỆ THỐNG PHÁT HIỆN VÀ NGĂN CHẶN XÂM NHẬP.....	120
5.3.1. Giới thiệu.....	120
5.3.2. Phân loại	121
5.3.3. Các kỹ thuật phát hiện xâm nhập	122
5.4. CÂU HỎI ÔN TẬP	124
CHƯƠNG 6. QUẢN LÝ, CHÍNH SÁCH VÀ PHÁP LUẬT AN TOÀN THÔNG TIN	125
6.1 QUẢN LÝ AN TOÀN THÔNG TIN.....	125
6.1.1. Khái quát về quản lý an toàn thông tin.....	125
6.1.2. Đánh giá rủi ro an toàn thông tin.....	126
6.1.3. Phân tích chi tiết rủi ro an toàn thông tin	128
6.1.4. Thực thi quản lý an toàn thông tin.....	131
6.2. CÁC CHUẨN QUẢN LÝ AN TOÀN THÔNG TIN	133
6.2.1. Giới thiệu.....	133
6.2.2. Chu trình Plan-Do-Check-Act	134
6.3. PHÁP LUẬT VÀ CHÍNH SÁCH AN TOÀN THÔNG TIN.....	135
6.3.1. Giới thiệu về pháp luật và chính sách an toàn thông tin.....	135
6.3.2. Luật quốc tế về an toàn thông tin	136
6.3.3. Luật Việt Nam về an toàn thông tin	138
6.4. VẤN ĐỀ ĐẠO ĐỨC AN TOÀN THÔNG TIN	138
6.4.1. Sự cần thiết của đạo đức an toàn thông tin.....	138
6.4.2. Một số bộ quy tắc ứng xử trong CNTT và ATTT	139
6.4.3. Một số vấn đề khác.....	139
6.5. CÂU HỎI ÔN TẬP	140
TÀI LIỆU THAM KHẢO	142

DANH MỤC CÁC HÌNH

Hình 1.1. Các thuộc tính cần bảo vệ của tài sản thông tin: Bí mật (Confidentiality), Toàn vẹn (Integrity) và Sẵn dùng (Availability) [1]	13
Hình 1.2. Mô hình hệ thống thông tin của cơ quan, tổ chức	14
Hình 1.3. Các thành phần của hệ thống thông tin và an toàn hệ thống thông tin.....	15
Hình 1.4. Số lượng các thiết bị kết nối vào Internet đến 2015 và dự báo đến 2021 [3].....	16
Hình 1.5. Số lượng các sự cố toàn hệ thống thông tin được thông báo đến Cơ quan ứng cứu khẩn cấp máy tính (US-CERT) trong giai đoạn 2006 – 2014 [4]	16
Hình 1.6. Một văn bản được đóng dấu Confidential (Mật).....	17
Hình 1.7. Đảm bảo tính bí mật bằng đường hầm VPN, hoặc mã hóa	18
Hình 1.8. Minh họa tính sẵn dùng: (a) không đảm bảo và (b) đảm bảo tính sẵn dùng	19
Hình 1.9. Các thành phần chính của An toàn thông tin [1]	19
Hình 1.10. Đảm bảo an toàn máy tính và dữ liệu.....	20
Hình 1.11. Đảm bảo an toàn cho thông tin và hệ thống mạng sử dụng tường lửa	21
Hình 1.12. Chu trình quản lý an toàn thông tin	21
Hình 1.13. Chính sách an toàn thông tin và các thành phần của nó.....	22
Hình 1.14. Bảy vùng trong hạ tầng CNTT theo mức kết nối mạng [2].....	22
Hình 1.15. Các lớp bảo vệ cần cân bằng giữa Tính hữu dụng (Usability), Chi phí (Cost) và An toàn (Security)	24
Hình 1.16. Mô hình đảm bảo an toàn thông tin với bảy lớp.....	25
Hình 1.17. Mô hình đảm bảo an toàn thông tin với ba lớp chính.....	25
Hình 2.1. Mô hình hệ điều hành Unix/Linux, các dịch vụ và ứng dụng	27
Hình 2.2. Phân bố lỗ hổng bảo mật trong các thành phần của hệ thống [6].....	29
Hình 2.3. Phân bố lỗ hổng bảo mật theo mức độ nghiêm trọng năm 2012 [6]	29
Hình 2.4. Phân bố lỗ hổng bảo mật theo mức độ nghiêm trọng giai đoạn 2005-2018 [6]	30
Hình 2.5. Lỗ hổng bảo mật phát hiện trong các năm 2011 và 2012 trên các hệ điều hành.....	30
Hình 2.6. Lỗ hổng bảo mật phát hiện trong các năm 2011 và 2012 trên một số ứng dụng.....	31
Hình 2.7. Các vùng bộ nhớ cấp cho chương trình.....	32
Hình 2.8. Một chương trình minh họa cấp phát bộ nhớ trong ngăn xếp	33
Hình 2.9. Các thành phần được lưu trong vùng bộ nhớ trong ngăn xếp	33
Hình 2.10. Cấp phát bộ nhớ cho các biến nhớ trong vùng bộ nhớ trong ngăn xếp	33
Hình 2.11. Một chương trình minh họa gây tràn bộ nhớ đệm trong ngăn xếp.....	34
Hình 2.12. Minh họa hiện tượng tràn bộ nhớ đệm trong ngăn xếp	34
Hình 2.13. Một shellcode viết bằng hợp ngữ và chuyển thành chuỗi tấn công.....	35
Hình 2.14. Chèn và thực hiện shellcode khai thác lỗi tràn bộ đệm	35
Hình 2.15. Chèn shellcode với phần đệm bằng lệnh NOP (N).....	36
Hình 2.16. Bản đồ lây nhiễm sâu Slammer (màu xanh) theo trang www.caida.org vào ngày 25/1/2003 lúc 6h00 (giờ UTC) với 74.855 máy chủ bị nhiễm	36
Hình 2.17. Cung cấp dữ liệu quá lớn để gây lỗi cho ứng dụng	38
Hình 2.18. Cân bằng giữa An toàn (Secure), Hữu dụng (Usable) và Rẻ tiền (Cheap).....	41
Hình 2.19. Báo cáo kết quả quét của Microsoft Baseline Security Analyzer.....	43
Hình 2.20. Màn hình tổng hợp kết quả quét lỗ hổng của Nessus Vulnerability Scanner.....	44
Hình 2.21. Kết quả quét website sử dụng Acunetix Web Vulnerability Scanner	45

Hình 3.1. Giao diện của công cụ quét cổng Zenmap.....	48
Hình 3.2. Sử dụng Wireshark để bắt gói tin có chứa thông tin nhạy cảm.....	49
Hình 3.3. Mô đun Keylogger phần cứng và cài đặt trên máy tính để bàn.....	49
Hình 3.4. Form đăng nhập (log in) và đoạn mã xử lý xác thực người dùng.....	52
Hình 3.5. Form tìm kiếm sản phẩm và đoạn mã xử lý tìm sản phẩm.....	53
Hình 3.6. (a) Thủ tục bắt tay 3 bước của giao thức TCP và (b) Tấn công SYN Flood.....	57
Hình 3.7. Mô hình tấn công Smurf.....	58
Hình 3.8. Kiến trúc tấn công DDoS trực tiếp.....	60
Hình 3.9. Kiến trúc tấn công DDoS gián tiếp hay phản xạ.....	61
Hình 3.10. Minh họa quá trình tấn công giả mạo địa chỉ IP.....	62
Hình 3.11. Một mô hình tấn công nghe lén.....	63
Hình 3.12. Mô hình chung của tấn công kiểu người đứng giữa.....	63
Hình 3.13. Một kịch bản tấn công kiểu người đứng giữa.....	64
Hình 3.14. Một phishing email gửi cho khách hàng của mạng đấu giá eBay.....	66
Hình 3.15. Một phishing email gửi cho khách hàng của ngân hàng Royal Bank.....	66
Hình 3.16. Tấn công pharming "cướp" trình duyệt.....	67
Hình 3.17. Tấn công pharming thông qua tấn công vào máy chủ DNS.....	68
Hình 3.18. Các dạng phần mềm độc hại.....	69
Hình 3.19. Minh họa bom lô gic.....	69
Hình 3.20. Minh họa trojan horse.....	70
Hình 3.21. Minh họa cửa hậu trên điện thoại Apple iPhone cho phép truy nhập trái phép.....	70
Hình 3.22. Minh họa vi rút máy tính.....	71
Hình 3.23. Chèn và gọi thực hiện mã vi rút.....	71
Hình 3.24. Macro vi rút chỉ lây nhiễm vào các tài liệu của bộ ứng dụng Microsoft Office.....	72
Hình 3.25. Một email vi rút gửi đến người dùng.....	73
Hình 3.26. Minh họa sâu máy tính.....	73
Hình 3.27. Bản đồ lây nhiễm sâu Code Red trên toàn thế giới.....	74
Hình 3.28. Mô hình kẻ tấn công sử dụng các máy tính Zombie để tấn công DDoS.....	75
Hình 3.29. Mô hình kẻ tấn công sử dụng các máy tính Zombie để gửi thư rác.....	75
Hình 3.30. Màn hình chính của Microsoft Windows Defender.....	77
Hình 4.1. Các khâu Mã hóa (Encryption) và Giải mã (Decryption) của một hệ mã hóa.....	79
Hình 4.2. Mã hóa khóa đối xứng sử dụng 1 khóa bí mật chia sẻ để mã hoá và giải mã.....	80
Hình 4.3. Mã hóa khóa bất đối xứng sử dụng một cặp khóa để mã hoá và giải mã.....	81
Hình 4.4. Minh họa đầu vào (Input) và đầu ra (Digest) của hàm băm.....	81
Hình 4.5. Các thành phần của một hệ mã hóa đơn giản.....	82
Hình 4.6. Mã hóa dòng (Stream cipher).....	82
Hình 4.7. Mã hóa khối (Block cipher).....	83
Hình 4.8. Mã hóa bằng hệ mã hóa Caesar cipher.....	84
Hình 4.9. Phương pháp thay thế với 4 bộ chữ mã.....	85
Hình 4.10. Phương pháp hoán vị thực hiện đổi chỗ các bit.....	85
Hình 4.11. Phương pháp hoán vị thực hiện đổi chỗ các ký tự.....	85
Hình 4.12. Mã hóa bằng phương pháp XOR.....	86
Hình 4.13. Mã hóa bằng phương pháp Vernam.....	86
Hình 4.14. Quá trình mã hóa khóa đối xứng (Symmetric key encryption).....	88
Hình 4.15. Mô hình các khâu mã hóa và giải mã của DES.....	88

Hình 4.16. Thủ tục sinh các khóa phụ từ khóa chính của DES	89
Hình 4.17. Các bước xử lý chuyển khối rõ 64 bit thành khối mã 64 bit của DES	90
Hình 4.18. Các bước xử lý của hàm Feistel (F).....	91
Hình 4.19. Mã hóa và giải mã với giải thuật 3-DES	91
Hình 4.20. Các bước xử lý mã hóa dữ liệu của AES.....	93
Hình 4.21. Thủ tục sinh khóa Rijndael.....	94
Hình 4.22. Hàm SubBytes sử dụng Rijndael S-box	94
Hình 4.23. Hàm ShiftRows	94
Hình 4.24. Hàm MixColumns	95
Hình 4.25. Hàm AddRoundKey	95
Hình 4.26. Quá trình mã hóa và giải mã trong AES.....	96
Hình 4.27. Mã hóa và giải mã trong hệ mã hóa bất đối xứng	96
Hình 4.28. Mô hình nén thông tin của hàm băm	99
Hình 4.29. Phân loại các hàm băm theo khóa sử dụng.....	100
Hình 4.30. Mô hình tổng quát xử lý dữ liệu của hàm băm.....	101
Hình 4.31. Mô hình chi tiết xử lý dữ liệu của hàm băm.....	101
Hình 4.32. Lưu đồ xử lý một thao tác của MD5.....	103
Hình 4.33. Lưu đồ một vòng xử lý của SHA1	104
Hình 5.1. Mô hình ma trận điều khiển truy nhập	106
Hình 5.2. Mô hình danh sách điều khiển truy nhập.....	107
Hình 5.3. Mô hình điều khiển truy nhập Bell-LaPadula	109
Hình 5.4. Một mô hình RBAC đơn giản	110
Hình 5.5. Giao diện kiểm tra thông tin của một chứng chỉ số khóa công khai	112
Hình 5.6. Thẻ thông minh tiếp xúc (a) và thẻ không tiếp xúc (b)	112
Hình 5.7. Một số thẻ bài (Token) của hãng RSA Security.....	113
Hình 5.8. Ví điện tử (một dạng thẻ bài) của cổng thanh toán trực tuyến Paypal	113
Hình 5.9. Hệ thống ApplePay tích hợp vào điện thoại di động.....	114
Hình 5.10. (a) Khóa vân tay, (b) Khe xác thực vân tay trên laptop và (c) Xác thực vân tay trên điện thoại thông minh Samsung	115
Hình 5.11. Quét võng mạc nhận dạng tròng mắt.....	115
Hình 5.12. Một tường lửa phần cứng chuyên dụng của hãng Cisco	116
Hình 5.13. Tường lửa bảo vệ mạng gia đình hoặc văn phòng nhỏ.....	116
Hình 5.14. Tường lửa bảo vệ các máy chủ dịch vụ	116
Hình 5.15. Hệ thống tường lửa bảo vệ các máy chủ dịch vụ và máy trạm.....	117
Hình 5.16. Mô hình tường lửa lọc gói (a), Cổng ứng dụng (b) và Cổng chuyển mạch (c) ...	118
Hình 5.17. Tường lửa có trạng thái chặn gói tin không thuộc kết nối đang hoạt động.....	119
Hình 5.18. Vị trí các hệ thống IDS và IPS trong sơ đồ mạng	120
Hình 5.19. Các NIDS được bố trí để giám sát phát hiện xâm nhập tại cổng vào và cho từng phân đoạn mạng.....	121
Hình 5.20. Sử dụng kết hợp NIDS và HIDS để giám sát lưu lượng mạng và các host.....	122
Hình 5.21. Lưu đồ giám sát phát hiện tấn công, xâm nhập dựa trên chữ ký	122
Hình 5.22. Giá trị entropy của IP nguồn của các gói tin từ lưu lượng hợp pháp (phần giá trị cao, đều) và entropy của IP nguồn của các gói tin từ lưu lượng tấn công DDoS (phần giá trị thấp).....	123
Hình 6.1. Mô hình hệ thống quản lý an toàn thông tin theo chuẩn ISO 27001.....	126

Hình 6.2. Mô hình đánh giá rủi ro an toàn thông tin	126
Hình 6.3. Chu trình Plan-Do-Check-Act của ISO/IEC 27001:2005	134
Hình 6.4. Vấn đề tuân thủ (Compliance) pháp luật, chính sách và các nội quy, quy định.....	136

ATTN.PTH

DANH MỤC CÁC THUẬT NGỮ TIẾNG ANH VÀ VIỆT TẮT

Từ viết tắt	Thuật ngữ tiếng Anh/Giải thích	Thuật ngữ tiếng Việt/Giải thích
AES	Advanced Encryption Standard	Chuẩn mã hóa tiên tiến
ATTT	Information Security	An toàn thông tin
CNTT	Information Technology	Công nghệ thông tin
CRC	Cyclic redundancy checks	Kiểm tra dư thừa vòng
CSDL	Database	Cơ sở dữ liệu
CSRF	Cross-Site Request Forgery	Tấn công giả mạo yêu cầu liên miền
DAC	Discretionary Access Control	Điều khiển truy nhập tùy chọn
DES	Data Encryption Standard	Chuẩn mã hóa dữ liệu
DNS	Domain Name System	Hệ thống tên miền
DDoS	Distributed Denial of Service	Tấn công từ chối dịch vụ phân tán
DoS	Denial of Service	Tấn công từ chối dịch vụ
FTP	File Transfer Protocol	Giao thức truyền file
HTTP	HyperText Transfer Protocol	Giao thức truyền siêu văn bản
HTTT	Information System	Hệ thống thông tin
IDEA	International Data Encryption Algorithm	Giải thuật mã hóa dữ liệu quốc tế
ICMP	Internet Control Message Protocol	Giao thức điều khiển truyền thông điệp
IP	Internet Protocol	Giao thức Internet
IPSec	Internet Protocol Security	An toàn giao thức Internet
IRC	Internet Relay Chat	Giao thức IRC
LAN	Local Area Network	Mạng cục bộ
MAC	Mandatory Access Control	Điều khiển truy nhập bắt buộc
MAC	Message Authentication Code	Mã xác thực thông điệp (sử dụng hàm băm có khóa)
MD	Message Digest	Chuỗi đại diện thông điệp
MDC	Modification Detection Code	Mã phát hiện sửa đổi (sử dụng hàm băm không khóa)
NSA	National Security Agency	Cơ quan mật vụ liên bang Hoa Kỳ
PGP	Pretty Good Privacy	Chuẩn bảo mật PGP
PKI	Public Key Infrastructure	Hạ tầng khóa công khai
RBAC	Role-Based Access Control	Điều khiển truy nhập dựa trên vai trò
RSA	RSA Public Key Cryptosystem	Hệ mật khóa công khai RSA
SET	Secure Electronic Transactions	Các giao dịch điện tử an toàn
SHA	Secure Hash Algorithm	Giải thuật băm an toàn

SMTP	Simple Mail Transfer Protocol	Giao thức truyền thư điện tử đơn giản
SQL	Structured Query Language	Ngôn ngữ truy vấn có cấu trúc
SSH	Secure Shell	Vô an toàn
SSL/TLS	Secure Socket Layer/Transport Layer Security	Bộ giao thức bảo mật SSL / TLS
SSO	Single Sign On	Đăng nhập một lần
TCP	Transmission Control Protocol	Giao thức điều khiển truyền
UDP	User Datagram Protocol	Giao thức gói dữ liệu người dùng
XSS	Cross-Site Scripting	Tấn công script liên miền
WAN	Wide Area Network	Mạng diện rộng
WLAN	Wireless Local Area Network	Mạng cục bộ không dây

MỞ ĐẦU

An toàn thông tin (Information security) là một lĩnh vực tương đối mới và được quan tâm trong vài thập kỷ gần đây và phát triển mạnh trong khoảng hơn một thập kỷ qua nhờ sự phát triển mạnh mẽ của mạng Internet và các dịch vụ mạng trên nền Internet. Tuy nhiên, do Internet ngày càng mở rộng và gần như không còn khái niệm biên giới quốc gia trong không gian mạng, các sự cố mất an toàn thông tin liên tục xảy ra. Đặc biệt, các dạng tấn công, xâm nhập vào các hệ thống máy tính và mạng xuất hiện ngày càng phổ biến với mức độ phá hoại ngày càng nghiêm trọng. Vấn đề đảm bảo an toàn cho thông tin, các hệ thống và mạng trở nên cấp thiết và là mối quan tâm của mỗi quốc gia, cơ quan, tổ chức và mỗi người dùng.

An toàn thông tin được định nghĩa là việc bảo vệ chống truy nhập, sử dụng, tiết lộ, sửa đổi, hoặc phá hủy thông tin một cách trái phép. Dưới một góc nhìn khác, An toàn thông tin là việc bảo vệ các thuộc tính, bao gồm tính bí mật, tính toàn vẹn và tính sẵn dùng của các tài sản thông tin trong quá trình chúng được lưu trữ, xử lý, hoặc truyền tải. An toàn thông tin có thể được chia thành ba thành phần chính: An toàn máy tính và dữ liệu, An ninh mạng và Quản lý an toàn thông tin.

Môn học Cơ sở an toàn thông tin là môn học cơ sở chuyên ngành trong chương trình đào tạo đại học các ngành An toàn thông tin và ngành Công nghệ thông tin (chuyên ngành An toàn thông tin) của Học viện Công nghệ Bưu chính Viễn thông. Mục tiêu của môn học cung cấp cho sinh viên các khái niệm và nguyên tắc cơ bản về đảm bảo an toàn thông tin, an toàn máy tính, an toàn hệ thống thông tin và mạng; các nguy cơ và các lỗ hổng gây mất an toàn; các dạng tấn công, xâm nhập thường gặp; các dạng phần mềm độc hại; các kỹ thuật, giải pháp và công cụ phòng chống, đảm bảo an toàn thông tin, hệ thống và mạng; vấn đề quản lý an toàn thông tin, chính sách, pháp luật và đạo đức an toàn thông tin.

Với phạm vi là một trong môn học cơ sở nhất về an toàn thông tin, tác giả cố gắng trình bày những vấn đề cơ sở nhất phục vụ mục tiêu môn học. Nội dung của giáo trình này được biên soạn thành 6 chương với tóm tắt nội dung như sau:

Chương 1- Tổng quan về an toàn thông tin giới thiệu các khái niệm về an toàn thông tin, an toàn hệ thống thông tin và các yêu cầu đảm bảo an toàn thông tin, an toàn hệ thống thông tin. Chương 1 cũng đề cập các nguy cơ, rủi ro trong các vùng của hạ tầng công nghệ thông tin theo mức kết nối mạng. Phần cuối của chương giới thiệu mô hình tổng quát đảm bảo an toàn thông tin và an toàn hệ thống thông tin.

Chương 2- Các lỗ hổng bảo mật và các điểm yếu hệ thống giới thiệu các khái niệm về các điểm yếu và lỗ hổng bảo mật tồn tại trong hệ thống, các dạng lỗ hổng bảo mật trong hệ điều hành và các phần mềm ứng dụng. Chương này đi sâu phân tích cơ chế xuất hiện và khai thác các lỗ hổng tràn bộ đệm và lỗ hổng không kiểm tra đầu vào. Phần cuối của chương đề cập vấn đề quản lý, khắc phục các lỗ hổng bảo mật, tăng cường khả năng đề kháng cho hệ thống và giới thiệu một số công cụ rà quét lỗ hổng bảo mật.

Chương 3- Các dạng tấn công và các phần mềm độc hại giới thiệu về các dạng tấn công điển hình vào các hệ thống máy tính và mạng, bao gồm tấn công vào mật khẩu, tấn công nghe lén, người đứng giữa, tấn công DoS, DDoS, tấn công sử dụng các kỹ thuật xã hội,... Nửa cuối của chương 3 đề cập đến các dạng phần mềm độc hại, gồm cơ chế lây nhiễm và tác hại của chúng. Kèm theo phần mô tả mỗi tấn công, hoặc phần mềm độc hại, chương đề cập các biện pháp, kỹ thuật phòng chống.

Chương 4 – Đảm bảo an toàn thông tin dựa trên mã hóa giới thiệu các khái niệm cơ bản về mật mã, hệ mã hóa, các phương pháp mã hóa. Phần tiếp theo của chương 4 trình bày một số giải thuật cơ bản của mã hóa khóa đối xứng (DES, 3-DES và AES), mã hóa khóa bất đối xứng (RSA) và các hàm băm (MD5 và SHA1).

Chương 5- Các kỹ thuật và công nghệ đảm bảo an toàn thông tin giới thiệu khái quát về điều khiển truy nhập, các cơ chế (mô hình) điều khiển truy nhập và một số công nghệ điều khiển truy nhập được sử dụng trên thực tế. Phần tiếp theo của chương 5 giới thiệu về tường lửa – một trong các kỹ thuật được sử dụng rất phổ biến trong đảm bảo an toàn cho hệ thống máy tính và mạng. Phần cuối của chương giới thiệu về các hệ thống phát hiện, ngăn chặn xâm nhập.

Chương 6 – Quản lý, chính sách và pháp luật an toàn thông tin giới thiệu một số khái niệm cơ bản trong quản lý an toàn thông tin, vấn đề đánh giá rủi ro an toàn thông tin và thực thi quản lý an toàn thông tin. Nội dung tiếp theo được đề cập là các chuẩn quản lý an toàn thông tin, trong đó giới thiệu một số chuẩn của bộ chuẩn ISO/IEC 27000. Phần cuối của chương giới thiệu khái quát về các vấn đề chính sách, pháp luật và đạo đức an toàn thông tin.

Tài liệu được biên soạn dựa trên kinh nghiệm giảng dạy các môn học Cơ sở an toàn thông tin trong nhiều năm của tác giả tại Học viện Công nghệ Bưu chính Viễn thông, kết hợp tiếp thu các đóng góp của đồng nghiệp và phản hồi từ sinh viên. Tài liệu có thể được sử dụng làm tài liệu học tập cho sinh viên hệ đại học các ngành An toàn thông tin và ngành Công nghệ thông tin (chuyên ngành An toàn thông tin). Trong quá trình biên soạn, mặc dù tác giả đã rất cố gắng song không thể tránh khỏi có những thiếu sót. Tác giả rất mong muốn nhận được ý kiến phản hồi và các góp ý cho các thiếu sót, cũng như ý kiến về việc cập nhật, hoàn thiện nội dung của tài liệu.

Hà Nội, Tháng 12 năm 2018

Tác giả

TS. Hoàng Xuân Dậu

CHƯƠNG 1. TỔNG QUAN VỀ AN TOÀN THÔNG TIN

Chương 1 giới thiệu các khái niệm về an toàn thông tin, an toàn hệ thống thông tin và các yêu cầu đảm bảo an toàn thông tin, an toàn hệ thống thông tin. Chương này cũng đề cập các nguy cơ, rủi ro trong các vùng của hạ tầng công nghệ thông tin theo mức kết nối mạng. Phần cuối của chương 1 giới thiệu mô hình tổng quát đảm bảo an toàn thông tin và an toàn hệ thống thông tin.

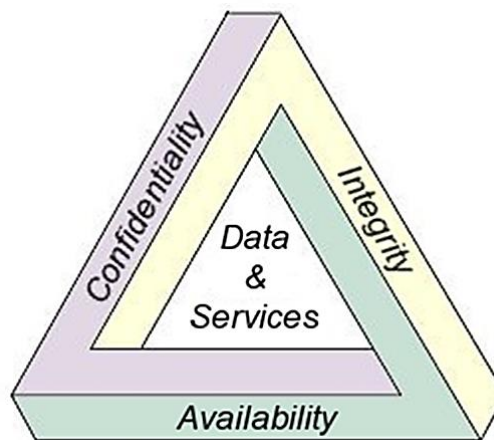
1.1. KHÁI QUÁT VỀ AN TOÀN THÔNG TIN

1.1.1. Một số khái niệm trong an toàn thông tin

1.1.1.1. An toàn thông tin

An toàn thông tin (Information security) là việc bảo vệ chống truy nhập, sử dụng, tiết lộ, sửa đổi, hoặc phá hủy thông tin một cách trái phép, theo trang Wikipedia¹.

Theo cuốn sách “Principles of Information Security” [1], An toàn thông tin là việc bảo vệ các thuộc tính bí mật (confidentiality), toàn vẹn (integrity) và sẵn dùng (availability) của các tài sản thông tin trong quá trình chúng được lưu trữ, xử lý, hoặc truyền tải. Hình 1.1 minh họa ba thuộc tính cần bảo vệ nói trên của các tài sản thông tin, bao gồm dữ liệu (Data) và dịch vụ (Services).



Hình 1.1. Các thuộc tính cần bảo vệ của tài sản thông tin: Bí mật (Confidentiality), Toàn vẹn (Integrity) và Sẵn dùng (Availability) [1]

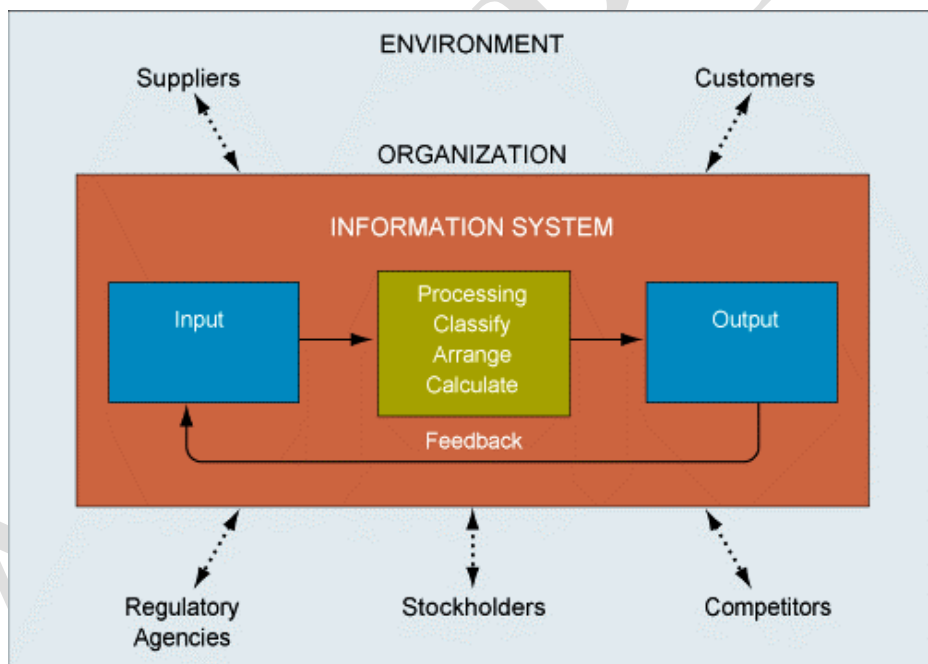
An toàn thông tin gồm hai lĩnh vực chính là An toàn công nghệ thông tin (Information technology security, hay IT security) và Đảm bảo thông tin (Information assurance). An toàn công nghệ thông tin, hay còn gọi là An toàn máy tính (Computer security) là việc đảm bảo an toàn cho các hệ thống công nghệ thông tin, bao gồm các hệ thống máy tính và mạng, chống lại các cuộc tấn công phá hoại. Đảm bảo thông tin là việc đảm bảo thông tin không bị mất khi xảy ra các sự cố, như thiên tai, hỏng hóc, trộm cắp, phá hoại,... Đảm bảo thông tin thường

¹ https://en.wikipedia.org/wiki/Information_security

được thực hiện sử dụng các kỹ thuật *sao lưu ngoại vi* (offsite backup), trong đó dữ liệu thông tin từ hệ thống gốc được sao lưu ra các thiết bị lưu trữ vật lý đặt ở một vị trí khác.

1.1.1.2. Hệ thống thông tin và an toàn hệ thống thông tin

Hệ thống thông tin (Information system), theo cuốn sách “Fundamentals of Information Systems Security” [2] là một hệ thống tích hợp các thành phần nhằm phục vụ việc thu thập, lưu trữ, xử lý thông tin, và chuyển giao thông tin, tri thức và các sản phẩm số. Trong nền kinh tế số, hệ thống thông tin đóng vai trò rất quan trọng trong hoạt động của các tổ chức, cơ quan và doanh nghiệp (gọi chung là tổ chức). Có thể nói, hầu hết các tổ chức đều sử dụng các hệ thống thông tin với các quy mô khác nhau để quản lý các hoạt động của mình. Hình 1.2 minh họa mô hình một hệ thống thông tin điển hình. Trong mô hình này, mỗi hệ thống thông tin gồm ba thành phần chính: (i) thành phần thu thập thông tin (Input), (ii) thành phần xử lý thông tin (Processing) và (iii) thành phần kết xuất thông tin (Output). Hệ thống thông tin được sử dụng để tương tác với khách hàng (Customers), với nhà cung cấp (Suppliers), với cơ quan chính quyền (Regulatory Agencies), với cổ đông (Stockholders) và với đối thủ cạnh tranh (Competitors). Có thể nêu là một số hệ thống thông tin điển hình như các hệ lập kế hoạch nguồn lực doanh nghiệp (Enterprise resource planning), các máy tìm kiếm (Search engine) và các hệ thống thông tin địa lý (Geographical information system).

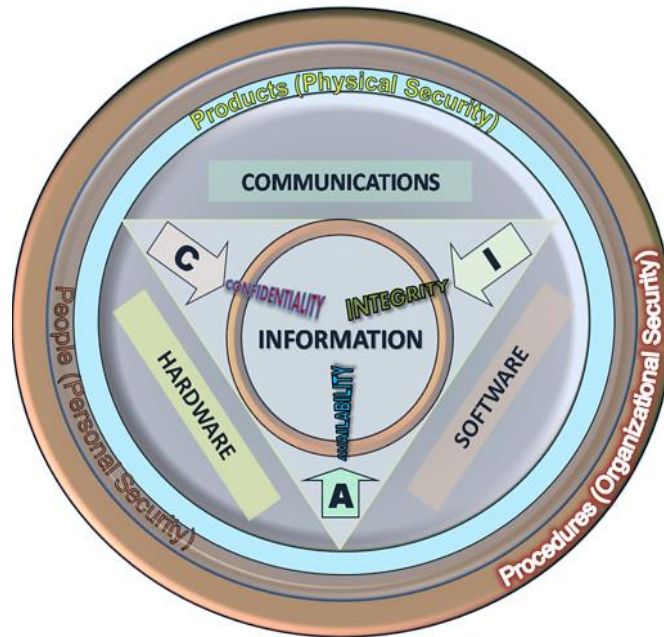


Hình 1.2. Mô hình hệ thống thông tin của cơ quan, tổ chức

Trong lớp các hệ thống thông tin, hệ thống thông tin dựa trên máy tính (Computer-based information system), hay sử dụng công nghệ máy tính để thực thi các nhiệm vụ là lớp hệ thống thông tin được sử dụng rộng rãi nhất. Hệ thống thông tin dựa trên máy tính thường gồm các thành phần chính: phần cứng (Hardware) để thu thập, lưu trữ, xử lý và biểu diễn dữ liệu; phần mềm (Software) chạy trên phần cứng để xử lý dữ liệu; và mạng/truyền thông (Network/Communication) là hệ thống truyền dẫn thông tin/dữ liệu. Ngoài ra, hệ thống thông tin dựa trên máy tính còn có thể gồm: cơ sở dữ liệu (Database) để lưu trữ dữ liệu và các thủ

tục (Procedure) là tập hợp các lệnh kết hợp các bộ phận nêu trên để xử lý dữ liệu, đưa ra kết quả mong muốn.

An toàn hệ thống thông tin (Information systems security) là việc đảm bảo các thuộc tính an ninh, an toàn của hệ thống thông tin, bao gồm tính *bí mật* (confidentiality), tính *toàn vẹn* (integrity) và tính *sẵn dùng* (availability). Hình 1.3 minh họa các thành phần cơ bản của Hệ thống thông tin dựa trên máy tính và An toàn hệ thống thông tin.



Hình 1.3. Các thành phần của hệ thống thông tin và an toàn hệ thống thông tin

1.1.1.3. Một số khái niệm khác

Truy nhập (Access) là việc một chủ thể, người dùng hoặc một đối tượng có khả năng sử dụng, xử lý, sửa đổi, hoặc gây ảnh hưởng đến một chủ thể, người dùng hoặc một đối tượng khác. Trong khi người dùng hợp pháp có quyền truy nhập hợp pháp đến một hệ thống thì kẻ tấn công truy nhập bất hợp pháp đến hệ thống.

Tài sản (Asset) là tài nguyên của các tổ chức, cá nhân được bảo vệ. Tài sản có thể là tài sản vô giá trị, như một trang web, thông tin, hoặc dữ liệu. Tài sản cũng có thể là tài sản vật lý, như hệ thống máy tính, thiết bị mạng, hoặc các tài sản khác.

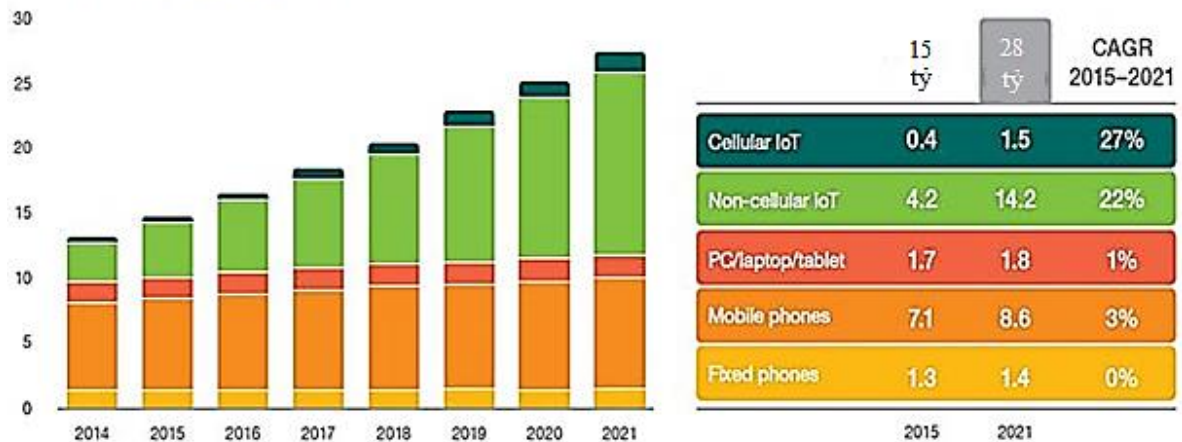
Tấn công (Attack) là hành động có chủ ý hoặc không có chủ ý có khả năng gây hại, hoặc làm thỏa hiệp các thông tin, hệ thống và các tài sản được bảo vệ. Tấn công có thể chủ động hoặc thụ động, trực tiếp hoặc gián tiếp.

1.1.2. Sự cần thiết của an toàn thông tin

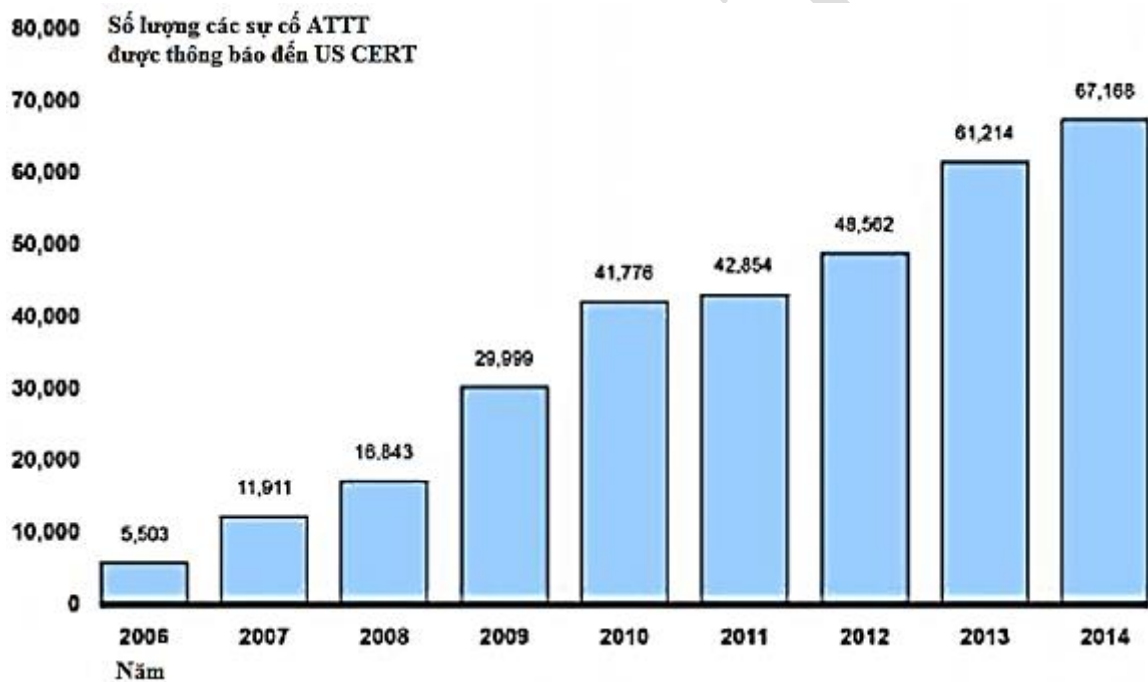
Trong những năm gần đây, cùng với sự phát triển mạnh mẽ của các thiết bị di động, và đặc biệt là các thiết bị IoT (Internet of Things), số lượng người dùng mạng Internet và số lượng thiết bị kết nối vào mạng Internet tăng trưởng nhanh chóng. Theo thống kê và dự báo của Forbes [3] cho trên Hình 1.4, số lượng các thiết bị có kết nối Internet là khoảng 15 tỷ trong năm 2015, tăng lên khoảng 20 tỷ vào năm 2018 và dự báo sẽ tăng mạnh lên khoảng 28 tỷ vào năm 2021. Các thiết bị IoT kết nối thông minh là nền tảng cho phát triển nhiều ứng

dụng quan trọng trong các lĩnh vực của đời sống xã hội, như thành phố thông minh, cộng đồng thông minh, ngôi nhà thông minh, các ứng dụng giám sát và chăm sóc sức khỏe,...

Thiết bị kết nối (đơn vị: tỷ cái)



Hình 1.4. Số lượng các thiết bị kết nối vào Internet đến 2015 và dự báo đến 2021 [3]



Hình 1.5. Số lượng các sự cố toàn hệ thống thông tin được thông báo đến Cơ quan ứng cứu khẩn cấp máy tính (US-CERT) trong giai đoạn 2006 – 2014 [4]

Cùng với những lợi ích to lớn mà các thiết bị kết nối Internet mạng lại, các sự cố mất an toàn thông tin đối với các hệ thống máy tính, điện thoại di động thông minh, các thiết bị IoT và người dùng cũng tăng vọt. Theo số liệu ghi nhận của Cơ quan Thống kê quốc gia Hoa Kỳ cho trên Hình 1.5, số lượng các sự cố mất an toàn hệ thống thông tin được thông báo đến Cơ quan ứng cứu khẩn cấp máy tính (US-CERT) trong giai đoạn 2006 – 2014 tăng rất mạnh, từ 5.503 vụ vào năm 2006 lên đến 67.168 vụ vào năm 2014. Ở Việt Nam, trong báo cáo “*Tổng kết an ninh mạng năm 2017 và dự báo xu hướng 2018*” [5], Tập đoàn công nghệ Bkav cho biết 12.300 tỷ đồng (tương đương khoảng 540 triệu USD) là tổng thiệt hại ước tính do vi rút

máy tính gây ra đối với người dùng Việt Nam trong năm 2017, vượt xa mốc 10.400 tỷ đồng thiệt hại do vi rút máy tính trong năm 2016. Dự báo trong năm 2018 và các năm tiếp theo, số lượng sự cố và thiệt hại do mất an toàn thông tin gây ra còn có thể lớn hơn nữa, do số lượng thiết bị kết nối tăng trưởng nhanh chóng và nguy cơ từ sự bùng phát mạnh của các phần mềm độc hại (các loại mã độc mã hóa tổng tiền (ransomware), mã độc đào tiền ảo...) và các kỹ thuật tấn công, phá hoại tinh vi (như các cuộc tấn công có chủ đích - APT).

Từ các số liệu nêu trên có thể khẳng định, việc đảm bảo an toàn cho thông tin, máy tính, hệ thống mạng và các thiết bị kết nối khác là rất cần thiết bởi 2 lý do: (1) số lượng các thiết bị có kết nối Internet tăng nhanh chóng, đặc biệt là các thiết bị thông minh, IoT và (2) sự bùng phát của các dạng mã độc, các dạng tấn công mạng trên diện rộng và các nguy cơ gây mất an toàn thông tin. Việc đảm bảo an toàn thông tin không chỉ cần thiết đối với các cá nhân, tổ chức, cơ quan, doanh nghiệp mà còn là vấn đề cấp thiết đối với an ninh quốc gia. Hơn nữa, việc xây dựng các giải pháp an toàn thông tin chỉ thực sự hiệu quả khi được thực hiện bài bản, đồng bộ, đảm bảo cân bằng giữa tính an toàn, tính hữu dụng của hệ thống và chi phí đầu tư cho các biện pháp đảm bảo an toàn.

1.2. CÁC YÊU CẦU ĐẢM BẢO ATTT VÀ HTTT

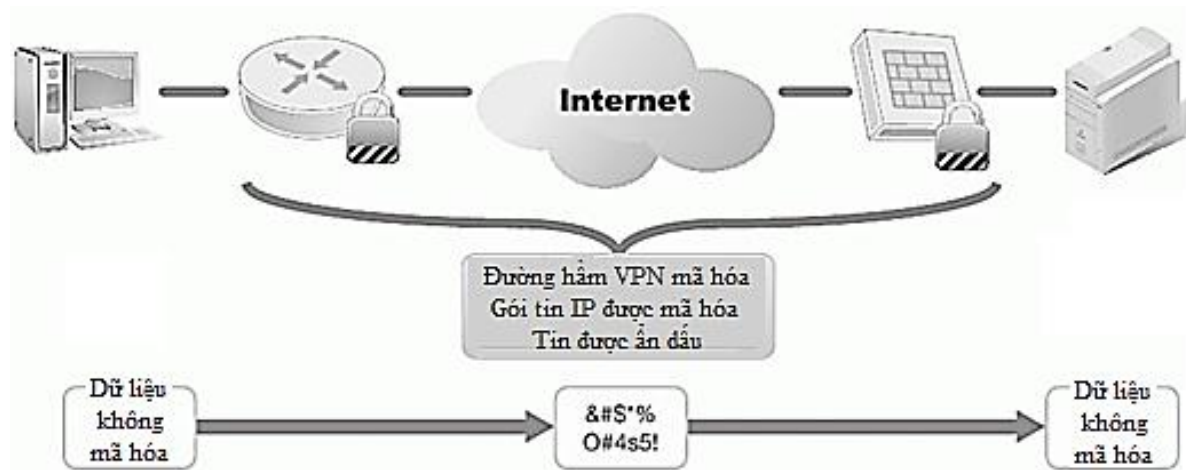
Như đã trình bày trong Mục 1.1, việc đảm bảo an toàn thông tin, hoặc hệ thống thông tin là việc đảm bảo ba thuộc tính của thông tin, hoặc hệ thống, bao gồm tính *Bí mật* (Confidentiality), tính *Toàn vẹn* (Integrity) và tính *Sẵn dùng* (Availability). Đây cũng là ba yêu cầu cơ bản trong đảm bảo an toàn thông tin và hệ thống thông tin.

1.2.1. Bí mật

Tính bí mật đảm bảo rằng chỉ người dùng có thẩm quyền mới được truy nhập thông tin, hệ thống. Các thông tin bí mật có thể bao gồm: (i) dữ liệu riêng của cá nhân, (ii) các thông tin thuộc quyền sở hữu trí tuệ của các doanh nghiệp hay các cơ quan, tổ chức và (iii) các thông tin có liên quan đến an ninh của các quốc gia và các chính phủ. Hình 1.6 minh họa một văn bản được đóng dấu *Confidential* (Mật), theo đó chỉ những người có thẩm quyền (có thể không gồm người soạn thảo văn bản) mới được đọc và phổ biến văn bản.



Hình 1.6. Một văn bản được đóng dấu Confidential (Mật)



Hình 1.7. Đảm bảo tính bí mật bằng đường hầm VPN, hoặc mã hóa

Thông tin bí mật lưu trữ hoặc trong quá trình truyền tải cần được bảo vệ bằng các biện pháp phù hợp, tránh bị lộ lọt hoặc bị đánh cắp. Các biện pháp có thể sử dụng để đảm bảo tính bí mật của thông tin như bảo vệ vật lý, hoặc sử dụng mật mã (cryptography). Hình 1.7 minh họa việc đảm bảo tính bí mật bằng cách sử dụng đường hầm VPN (Virtual private network), hoặc mã hóa để truyền tải thông tin.

1.2.2. Toàn vẹn

Tính toàn vẹn đảm bảo rằng thông tin và dữ liệu chỉ có thể được sửa đổi bởi những người dùng có thẩm quyền. Tính toàn vẹn liên quan đến tính hợp lệ (validity) và chính xác (accuracy) của dữ liệu. Trong nhiều tổ chức, thông tin và dữ liệu có giá trị rất lớn, như bản quyền phần mềm, bản quyền âm nhạc, bản quyền phát minh, sáng chế. Mọi thay đổi không có thẩm quyền có thể ảnh hưởng rất nhiều đến giá trị của thông tin. Thông tin hoặc dữ liệu là toàn vẹn nếu nó thỏa mãn ba điều kiện:

- Không bị thay đổi;
- Hợp lệ, và
- Chính xác.

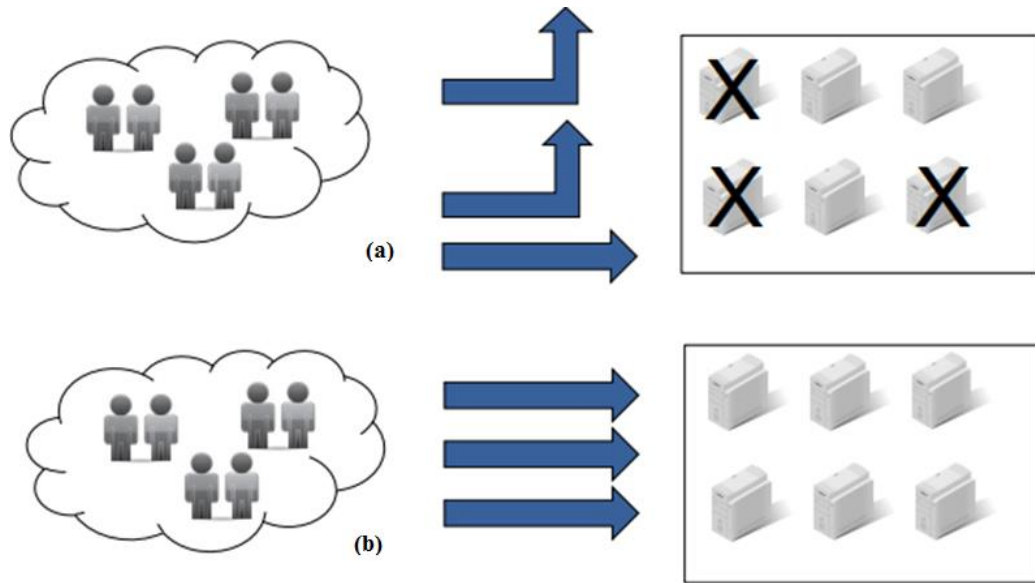
1.2.3. Sẵn dùng

Tính sẵn dùng, hoặc khả dụng đảm bảo rằng thông tin, hoặc hệ thống có thể truy nhập bởi người dùng hợp pháp bất cứ khi nào họ có yêu cầu. Tính sẵn dùng có thể được đo thông qua các yếu tố:

- Thời gian cung cấp dịch vụ (Uptime);
- Thời gian ngừng cung cấp dịch vụ (Downtime);
- Tỷ lệ phục vụ: $A = \text{Uptime} / (\text{Uptime} + \text{Downtime})$;
- Thời gian trung bình giữa các sự cố;
- Thời gian trung bình ngừng để sửa chữa;
- Thời gian khôi phục sau sự cố.

Hình 1.8 minh họa tính sẵn dùng của một hệ thống trong 2 trường hợp: trường hợp (a) hệ thống không đảm bảo tính sẵn dùng khi có một số thành phần gặp sự cố khi không có khả

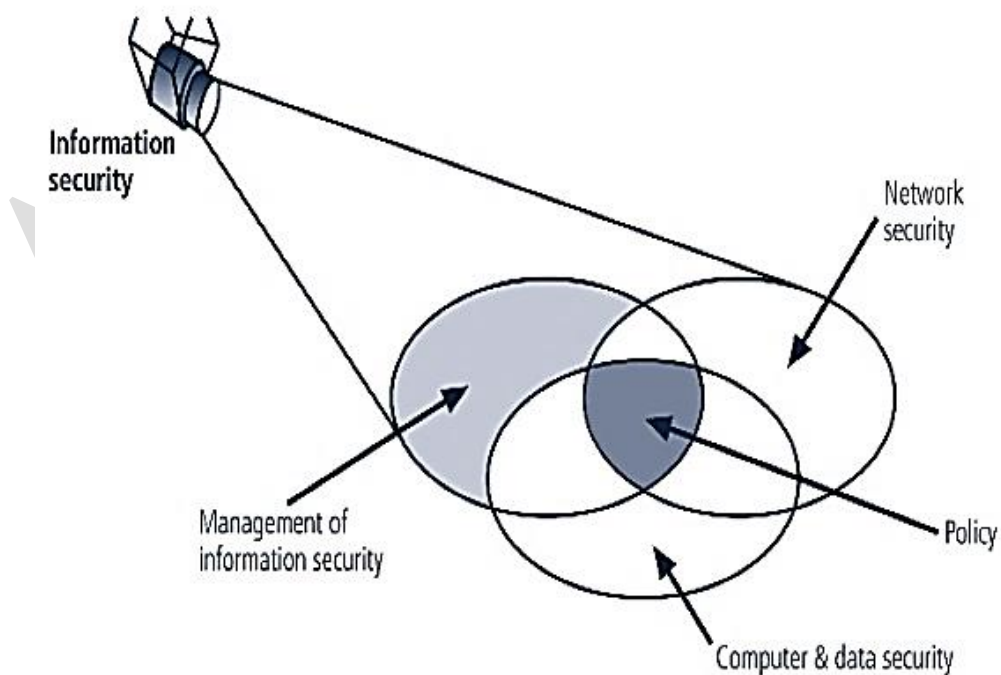
năng phục vụ tất cả các yêu cầu của người dùng và (b) hệ thống đảm bảo tính sẵn dùng khi các thành phần của nó hoạt động bình thường.



Hình 1.8. Minh họa tính sẵn dùng: (a) không đảm bảo và (b) đảm bảo tính sẵn dùng

1.3. CÁC THÀNH PHẦN CỦA AN TOÀN THÔNG TIN

An toàn thông tin có thể được chia thành ba thành phần chính: *An toàn máy tính và dữ liệu* (Computer & data security), *An ninh mạng* (Network security) và *Quản lý an toàn thông tin* (Management of information security) [1]. Ba thành phần trên của an toàn thông tin có quan hệ mật thiết và giao thoa với nhau, trong đó phần chung của cả ba thành phần trên là *Chính sách an toàn thông tin* (Policy) như minh họa trên Hình 1.9.



Hình 1.9. Các thành phần chính của An toàn thông tin [1]

1.3.2. An toàn máy tính và dữ liệu

An toàn máy tính và dữ liệu là việc đảm bảo an toàn cho hệ thống phần cứng, phần mềm và dữ liệu trên máy tính; đảm bảo cho máy tính có thể vận hành an toàn, đáp ứng các yêu cầu của người sử dụng. An toàn máy tính và dữ liệu bao gồm các nội dung:

- Đảm bảo an toàn hệ điều hành, ứng dụng, dịch vụ;
- Vấn đề điều khiển truy nhập;
- Vấn đề mã hóa và bảo mật dữ liệu;
- Vấn đề phòng chống phần mềm độc hại;
- Việc sao lưu tạo dự phòng dữ liệu, đảm bảo dữ liệu lưu trong máy tính không bị mất mát khi xảy ra sự cố.



Hình 1.10. Đảm bảo an toàn máy tính và dữ liệu

1.3.3. An ninh mạng

An ninh mạng là việc đảm bảo an toàn cho hệ thống mạng và các thông tin truyền tải trên mạng, chống lại các dạng tấn công, xâm nhập trái phép. Các kỹ thuật và công cụ thường được sử dụng trong an ninh mạng bao gồm:

- Các tường lửa, proxy cho lọc gói tin và điều khiển truy nhập;
- Mạng riêng ảo và các kỹ thuật bảo mật thông tin truyền như SSL/TLS, PGP;
- Các kỹ thuật và hệ thống phát hiện, ngăn chặn tấn công, xâm nhập;
- Vấn đề giám sát mạng.

1.3.4. Quản lý an toàn thông tin

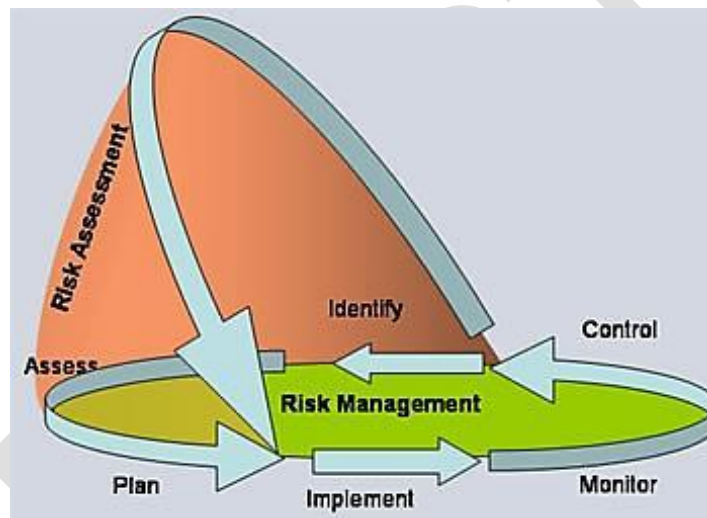
Quản lý an toàn thông tin là việc quản lý và giám sát việc thực thi các biện pháp đảm bảo an toàn thông tin, giúp nâng cao hiệu quả của chúng. Một trong các nội dung cốt lõi của quản lý an toàn thông tin là việc quản lý các rủi ro (risk management), trong đó việc nhận dạng và đánh giá rủi ro (risk assessment) đóng vai trò then chốt. Các nội dung khác của quản lý an toàn thông tin, bao gồm các chuẩn quản lý an toàn thông tin, chính sách an toàn thông tin và vấn đề đào tạo, nâng cao ý thức an toàn thông tin của người dùng.

Việc thực thi quản lý an toàn thông tin cần được thực hiện theo chu trình lặp lại, từ khâu lập kế hoạch (Plan), thực thi kế hoạch (Implement), giám sát kết quả thực hiện (Monitor) và

thực thi các kiểm soát (Control) như minh họa trên Hình 1.12, do các điều kiện bên trong và bên ngoài hệ thống luôn thay đổi theo thời gian.



Hình 1.11. Đảm bảo an toàn cho thông tin và hệ thống mạng sử dụng tường lửa



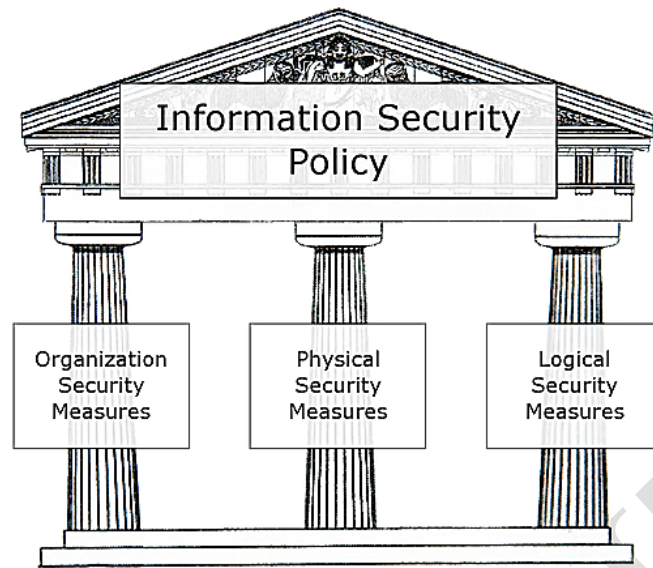
Hình 1.12. Chu trình quản lý an toàn thông tin

1.3.5. Chính sách an toàn thông tin

Chính sách an toàn thông tin (Information security policy) là các nội quy, quy định của cơ quan, tổ chức, nhằm đảm bảo các biện pháp đảm bảo an toàn thông tin được thực thi và tuân thủ. Chính sách an toàn thông tin, như minh họa trên Hình 1.13 gồm 3 thành phần:

- Chính sách an toàn ở mức vật lý (Physical security policy);
- Chính sách an toàn ở mức tổ chức (Organizational security policy);
- Chính sách an toàn ở mức logic (Logical security policy).

Một ví dụ về chính sách an toàn thông tin: để tăng cường an toàn cho hệ thống công nghệ thông tin, một tổ chức có thể áp dụng chính sách xác thực ‘mạnh’ sử dụng các đặc điểm sinh trắc (Biometrics), như xác thực sử dụng vân tay thay cho mật khẩu truyền thống cho hệ thống cửa ra vào trung tâm dữ liệu, hoặc đăng nhập vào hệ thống máy tính.



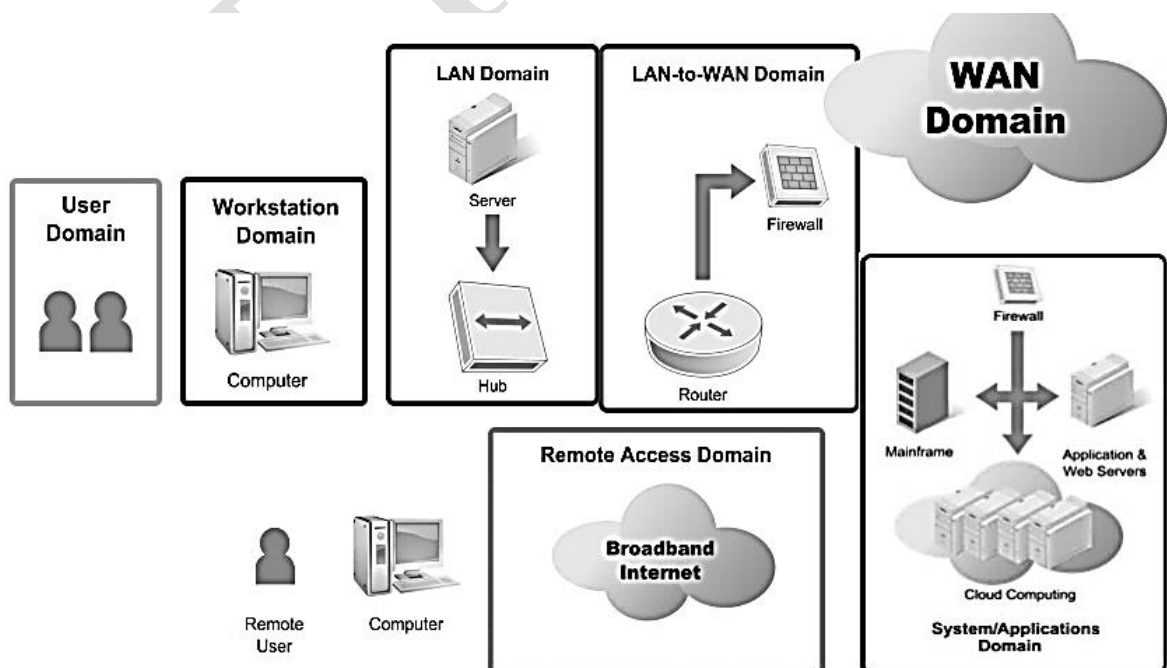
Hình 1.13. Chính sách an toàn thông tin và các thành phần của nó

1.4. CÁC MỐI ĐE DỌA VÀ NGUY CƠ TRONG CÁC VÙNG HẠ TẦNG CNTT

1.4.1. Bảy vùng trong cơ sở hạ tầng CNTT

Hạ tầng công nghệ thông tin (IT infrastructure) của các tổ chức, cơ quan, doanh nghiệp có thể có quy mô lớn hay nhỏ khác nhau, nhưng thường gồm bảy vùng theo mức kết nối mạng như minh họa trên Hình 1.14 [2].

Các vùng cụ thể gồm: vùng người dùng (User domain), vùng máy trạm (Workstation domain), vùng mạng LAN (LAN domain), vùng LAN-to-WAN (LAN-to-WAN domain), vùng mạng WAN (WAN domain), vùng truy nhập từ xa (Remote Access domain) và vùng hệ thống/ứng dụng (Systems/Applications domain). Do mỗi vùng kể trên có đặc điểm khác nhau nên chúng có các mối đe dọa và nguy cơ mất an toàn thông tin khác nhau.



Hình 1.14. Bảy vùng trong hạ tầng CNTT theo mức kết nối mạng [2]

1.4.2. Các mối đe dọa và nguy cơ trong các vùng hạ tầng CNTT

Vùng người dùng

Có thể nói vùng người dùng là vùng có nhiều mối đe dọa và nguy cơ nhất do người dùng có bản chất khó đoán định và khó kiểm soát hành vi. Các vấn đề thường gặp như thiếu ý thức, coi nhẹ vấn đề an ninh an toàn, vi phạm các chính sách an ninh an toàn; đưa CD/DVD/USB với các file cá nhân vào hệ thống; tải ảnh, âm nhạc, video trái phép; phá hoại dữ liệu, ứng dụng và hệ thống; ngoài ra, các nhân viên bất mãn có thể tấn công hệ thống từ bên trong, hoặc nhân viên có thể tống tiền hoặc chiếm đoạt thông tin nhạy cảm, thông tin quan trọng.

Vùng máy trạm

Vùng máy trạm cũng có nhiều mối đe dọa và nguy cơ do vùng máy trạm tiếp xúc trực tiếp với vùng người dùng. Các nguy cơ thường gặp gồm: truy nhập trái phép vào máy trạm, hệ thống, ứng dụng và dữ liệu; các lỗ hổng an ninh trong hệ điều hành, trong các phần mềm ứng dụng máy trạm; các hiểm họa từ vi rút, mã độc và các phần mềm độc hại. Ngoài ra, vùng máy trạm cũng chịu các nguy cơ do hành vi bị cấm từ người dùng, như đưa CD/DVD/USB với các file cá nhân vào hệ thống; tải ảnh, âm nhạc, video trái phép.

Vùng mạng LAN

Các nguy cơ có thể có đối với vùng mạng LAN bao gồm: truy nhập trái phép vào mạng LAN vật lý, truy nhập trái phép vào hệ thống, ứng dụng và dữ liệu; các lỗ hổng an ninh trong hệ điều hành và các phần mềm ứng dụng máy chủ; nguy cơ từ người dùng giả mạo trong mạng WLAN; tính bí mật dữ liệu trong mạng WLAN có thể bị đe dọa do sóng mang thông tin của WLAN truyền trong không gian có thể bị nghe trộm. Ngoài ra, các hướng dẫn và cấu hình chuẩn cho máy chủ trong mạng LAN nếu không được tuân thủ nghiêm ngặt sẽ dẫn đến những lỗ hổng an ninh mà kẻ tấn công có thể khai thác.

Vùng mạng LAN-to-WAN

Vùng mạng LAN-to-WAN là vùng chuyển tiếp từ mạng nội bộ ra mạng diện rộng, nên nguy cơ lớn nhất là kẻ tấn công từ mạng WAN có thể thăm dò và rà quét trái phép các cổng dịch vụ, nguy cơ truy nhập trái phép. Ngoài ra, một nguy cơ khác cần phải xem xét là lỗ hổng an ninh trong các bộ định tuyến, tường lửa và các thiết bị mạng khác.

Vùng mạng WAN

Vùng mạng WAN, hay mạng Internet là vùng mạng mở, trong đó hầu hết dữ liệu được truyền dưới dạng rõ, nên các nguy cơ lớn nhất là dễ bị nghe trộm và dễ bị tấn công phá hoại, tấn công từ chối dịch vụ (DoS) và từ chối dịch vụ phân tán (DDoS). Kẻ tấn công có thể tự do, dễ dàng gửi email có đính kèm vi rút, sâu và các phần mềm độc hại.

Vùng truy nhập từ xa

Trong vùng truy nhập từ xa, các nguy cơ điển hình bao gồm: tấn công kiểu vét cạn vào tên người dùng và mật khẩu, tấn công vào hệ thống đăng nhập và điều khiển truy nhập; truy nhập trái phép vào hệ thống CNTT, ứng dụng và dữ liệu; các thông tin bí mật có thể bị đánh cắp từ xa; và vấn đề rò rỉ dữ liệu do vi phạm các tiêu chuẩn phân loại dữ liệu.

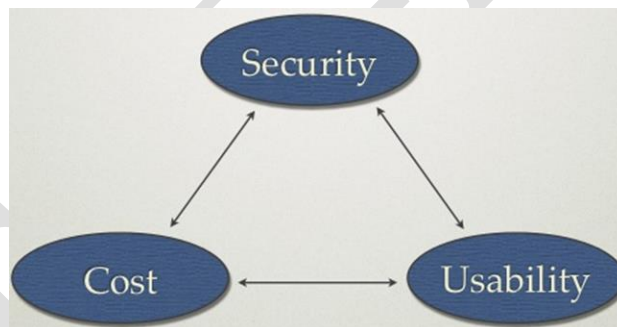
Vùng hệ thống và ứng dụng

Trong vùng hệ thống và ứng dụng, các nguy cơ có thể bao gồm: truy nhập trái phép đến trung tâm dữ liệu, phòng máy hoặc tủ cáp; các khó khăn trong quản lý các máy chủ với yêu cầu tính sẵn dùng cao; các lỗ hổng trong quản lý các phần mềm ứng dụng của hệ điều hành máy chủ; các vấn đề an ninh trong các môi trường ảo của điện toán đám mây; và vấn đề hỏng hóc hoặc mất dữ liệu.

1.5. MÔ HÌNH TỔNG QUÁT ĐẢM BẢO ATTT VÀ HỆ THỐNG THÔNG TIN

1.5.1. Nguyên tắc đảm bảo an toàn thông tin, hệ thống và mạng

Nguyên tắc chủ đạo xuyên suốt trong đảm bảo an toàn thông tin, hệ thống và mạng là *Phòng vệ nhiều lớp có chiều sâu* (Defence in depth). Theo nguyên tắc này, ta cần tạo ra nhiều lớp bảo vệ, kết hợp tính năng, tác dụng của mỗi lớp để đảm bảo an toàn tối đa cho thông tin, hệ thống và mạng. Một lớp, một công cụ phòng vệ riêng rẽ dù có hiện đại, nhưng vẫn không thể đảm bảo an toàn. Do vậy, việc tạo ra nhiều lớp bảo vệ có khả năng bổ sung cho nhau là cách làm hiệu quả. Một điểm quan trọng khác cần lưu ý khi thiết kế và triển khai hệ thống đảm bảo an toàn thông tin là cần cân bằng giữa *tính hữu dụng* (Usability), *chi phí* (Cost) và *an toàn* (Security), như minh họa trên Hình 1.15. Hệ thống đảm bảo an toàn thông tin chỉ thực sự phù hợp và hiệu quả khi hệ thống được bảo vệ đạt mức an toàn phù hợp mà vẫn có khả năng cung cấp các tính năng hữu dụng cho người dùng với chi phí cho đảm bảo an toàn phù hợp với giá trị của tài sản được bảo vệ.



Hình 1.15. Các lớp bảo vệ cần cân bằng giữa Tính hữu dụng (Usability), Chi phí (Cost) và An toàn (Security)

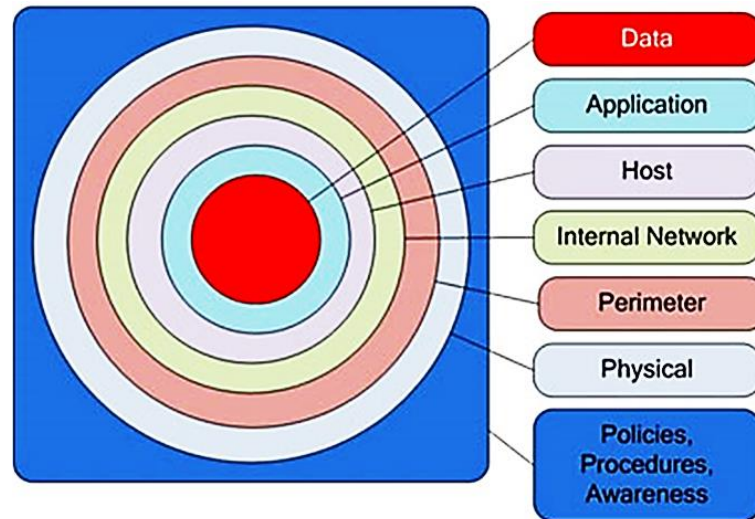
1.5.2. Mô hình tổng quát đảm bảo an toàn thông tin và hệ thống thông tin

Hình 1.16 minh họa mô hình đảm bảo an toàn thông tin với bảy lớp bảo vệ, bao gồm lớp chính sách, thủ tục, ý thức (Policies, procedures, awareness); lớp vật lý (Physical); lớp ngoại vi (Perimeter); lớp mạng nội bộ (Internal network); lớp host (Host); lớp ứng dụng (Application) và lớp dữ liệu (Data). Trong mô hình này, để truy nhập được đến đối tượng đích là dữ liệu, kẻ tấn công cần phải vượt qua cả 7 lớp bảo vệ.

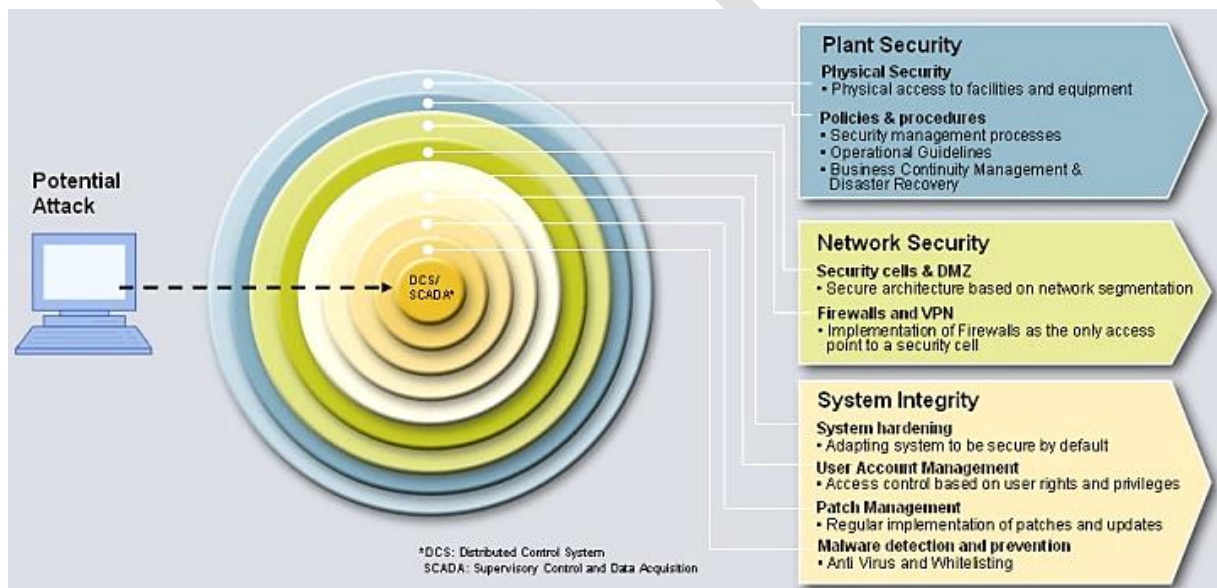
Tương tự, Hình 1.17 minh họa mô hình phòng vệ gồm 3 lớp chính: lớp an ninh cơ quan/tổ chức (Plant Security), lớp an ninh mạng (Network Security) và lớp an ninh hệ thống (System Integrity). Mỗi lớp chính lại gồm một số lớp con như sau:

- Lớp an ninh cơ quan/tổ chức gồm 2 lớp con:

- + Lớp bảo vệ vật lý (Physical Security) có nhiệm vụ kiểm soát các truy nhập vật lý đến các trang thiết bị hệ thống và mạng.
- + Lớp chính sách & thủ tục (Policies & procedures) bao gồm các quy trình quản lý an toàn thông tin, các hướng dẫn vận hành, quản lý hoạt động liên tục và phục hồi sau sự cố.



Hình 1.16. Mô hình đảm bảo an toàn thông tin với bảy lớp



Hình 1.17. Mô hình đảm bảo an toàn thông tin với ba lớp chính

- Lớp an ninh mạng gồm 2 lớp con:
 - + Lớp bảo vệ vùng hạn chế truy nhập (Security cells and DMZ) cung cấp các biện pháp bảo vệ cho từng phân đoạn mạng.
 - + Lớp các tường lửa, mạng riêng ảo (Firewalls and VPN) được triển khai như điểm truy nhập duy nhất đến một phân đoạn mạng.

- Lớp an ninh hệ thống gồm 4 lớp con:
 - + Lớp tăng cường an ninh hệ thống (System hardening) đảm bảo việc cài đặt và cấu hình các thành phần trong hệ thống đảm bảo các yêu cầu an toàn.
 - + Lớp quản trị tài khoản người dùng (User Account Management) thực hiện kiểm soát truy nhập dựa trên quyền truy nhập và các đặc quyền của người dùng.
 - + Lớp quản lý các bản vá (Patch Management) có nhiệm vụ định kỳ cài đặt các bản vá an ninh và các bản cập nhật cho hệ thống.
 - + Lớp phát hiện và ngăn chặn phần mềm độc hại (Malware detection and prevention) có nhiệm vụ bảo vệ hệ thống, chống vi rút và các phần mềm độc hại khác.

1.6. CÂU HỎI ÔN TẬP

- 1) An toàn thông tin (Information Security) là gì?
- 2) Tại sao cần phải đảm bảo an toàn cho thông tin?
- 3) Đảm bảo thông tin thường được thực hiện bằng cách nào?
- 4) An toàn hệ thống thông tin là gì?
- 5) Nêu các yêu cầu đảm bảo an toàn thông tin và hệ thống thông tin.
- 6) An toàn thông tin gồm những thành phần cơ bản nào? Mô tả vắn tắt chức năng của mỗi thành phần.
- 7) Nêu các rủi ro trong vùng người dùng và vùng máy trạm trong hạ tầng CNTT. Tại sao nói vùng người dùng là vùng có nhiều nguy cơ và rủi ro nhất?
- 8) Nêu các rủi ro trong vùng mạng LAN, LAN-to-WAN và vùng mạng WAN trong hạ tầng CNTT. Tại sao vùng mạng WAN có nguy cơ bị tấn công phá hoại cao?
- 9) Nguyên tắc cơ bản cho đảm bảo an toàn thông tin, hệ thống và mạng là gì?
- 10) Mô tả một mô hình nhiều lớp cho đảm bảo an toàn thông tin và hệ thống thông tin.

CHƯƠNG 2. LỖ HỔNG BẢO MẬT VÀ ĐIỂM YẾU HỆ THỐNG

Chương 2 giới thiệu các khái niệm về lỗ hổng bảo mật và điểm yếu tồn tại trong hệ thống, các dạng lỗ hổng bảo mật trong hệ điều hành và các phần mềm ứng dụng. Chương đi sâu phân tích cơ chế xuất hiện và khai thác các lỗ hổng tràn bộ đệm và lỗ hổng không kiểm tra đầu vào. Phần cuối của chương đề cập vấn đề quản lý, khắc phục các lỗ hổng bảo mật, tăng cường khả năng đề kháng cho hệ thống và giới thiệu một số công cụ rà quét lỗ hổng bảo mật.

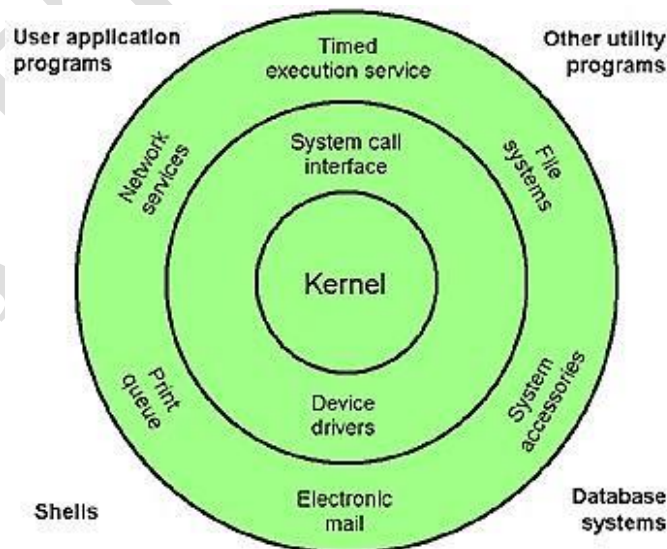
2.1. TỔNG QUAN VỀ LỖ HỔNG BẢO MẬT VÀ ĐIỂM YẾU HỆ THỐNG

2.1.1. Khái quát về điểm yếu hệ thống và lỗ hổng bảo mật

2.1.1.1. Các thành phần của hệ thống

Một hệ thống máy tính gồm 2 thành phần cơ bản là hệ thống phần cứng và hệ thống phần mềm. Hệ thống phần cứng bao gồm các mô đun phần cứng tạo nên máy tính vật lý, bao gồm CPU, ROM, RAM, Bus,...; các giao diện ghép nối và các thiết bị ngoại vi, như bàn phím, màn hình, ổ đĩa,... và các giao diện ghép nối mạng LAN, WLAN,...

Hệ thống phần mềm bao gồm hệ điều hành và các phần mềm ứng dụng. Hệ điều hành cung cấp môi trường làm việc cho các ứng dụng và giao diện người dùng. Hệ điều hành được cấu thành từ nhân hệ điều hành, các trình điều khiển thiết bị, trình quản lý tiến trình, trình quản lý file, các trình cung cấp dịch vụ, tiện ích,... Các phần mềm ứng dụng là các chương trình cung cấp các tính năng hữu ích cho người dùng, bao gồm các dịch vụ (máy chủ web, cơ sở dữ liệu, DNS,...), các trình duyệt web, các ứng dụng giao tiếp, các bộ ứng dụng văn phòng, các công cụ lập trình, phát triển phần mềm... Hình 2.1 minh họa mô hình hệ điều hành Unix/Linux, các dịch vụ và ứng dụng.



Hình 2.1. Mô hình hệ điều hành Unix/Linux, các dịch vụ và ứng dụng

2.1.1.2. Điểm yếu hệ thống và lỗ hổng bảo mật

Trên thực tế, gần như không có hệ thống nào là hoàn hảo, không có điểm yếu, hoặc khiếm khuyết. Các hệ thống máy tính, hoặc hệ thống thông tin là các hệ thống rất phức tạp, được cấu

thành từ nhiều thành phần phần cứng, phần mềm, do vậy trong chúng luôn tồn tại các lỗi, các khiếm khuyết, hay các điểm yếu. Các điểm yếu có thể tồn tại trong các mô đun phần cứng cũng như trong các mô đun phần mềm. Nhìn chung, các hệ thống càng phức tạp, nhiều thành phần và nhiều tính năng thì khả năng xuất hiện các lỗi và điểm yếu càng tăng.

Các điểm yếu hệ thống (System weakness) là các lỗi hay các khiếm khuyết tồn tại trong hệ thống. Nguyên nhân của sự tồn tại các điểm yếu có thể do lỗi thiết kế, lỗi cài đặt, lỗi lập trình, hoặc lỗi quản trị, lỗi cấu hình hoạt động. Các điểm yếu có thể tồn tại trong cả các mô đun phần cứng và các mô đun phần mềm. Một số điểm yếu được phát hiện và đã được khắc phục. Tuy nhiên, cũng có những điểm yếu được phát hiện nhưng chưa được khắc phục, hoặc các điểm yếu chưa được phát hiện, hoặc chỉ tồn tại trong một điều kiện đặc biệt nào đó.

Lỗ hổng bảo mật (Security vulnerability) là một điểm yếu tồn tại trong một hệ thống cho phép kẻ tấn công khai thác gây tổn hại đến các thuộc tính an toàn, an ninh của hệ thống đó, bao gồm tính bí mật, tính toàn vẹn và tính sẵn dùng. Phụ thuộc vào khả năng bị khai thác, các lỗ hổng bảo mật có mức độ nghiêm trọng (severity) khác nhau. Theo Microsoft, có 4 mức độ nghiêm trọng của các lỗ hổng bảo mật: *nguy hiểm* (Critical), *quan trọng* (Important), *trung bình* (Moderate) và *thấp* (Low). Tuy nhiên, một số tổ chức khác chỉ phân loại các lỗ hổng bảo mật theo 3 mức độ nghiêm trọng: *cao* (High), *trung bình* (Medium) và *thấp* (Low).

Lỗ hổng bảo mật thuộc *cấp độ nguy hiểm* là lỗ hổng cho phép kẻ tấn công thực hiện mã khai thác mà không cần tương tác người dùng. Các thông tin khai thác lỗ hổng, như mã mẫu khai thác tồn tại phổ biến trên mạng Internet. Ngoài ra, việc khai thác lỗ hổng có thể được thực hiện dễ dàng mà không yêu cầu có tài khoản trong hệ thống hoặc các điều kiện phức tạp. Ví dụ như một số lỗ hổng tràn bộ đệm thuộc cấp độ nguy hiểm do có thể bị khai thác bởi sâu mạng hoặc email chứa vi rút, mã độc. Các lỗ hổng loại nguy hiểm cần được khắc phục ngay hoặc càng sớm càng tốt.

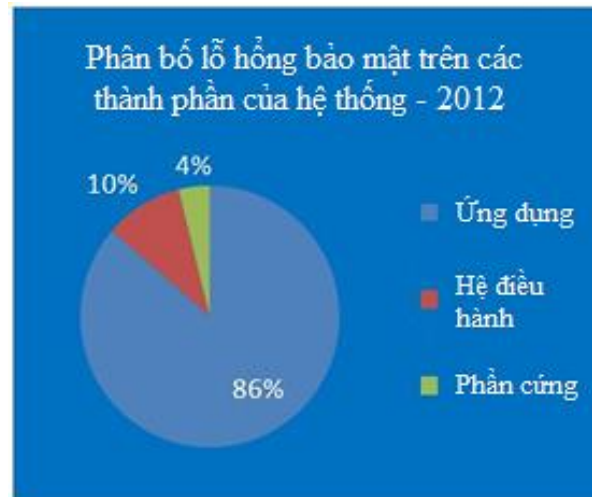
Lỗ hổng bảo mật thuộc *cấp độ quan trọng* là lỗ hổng khi bị khai thác có thể dẫn đến vi phạm các yêu cầu an toàn thông tin như bí mật, toàn vẹn và sẵn dùng của dữ liệu, tài nguyên tính toán, hoặc cả hệ thống. Khác với lỗ hổng loại nguy hiểm, lỗ hổng loại quan trọng cho phép kẻ tấn công thực hiện mã khai thác, nhưng cần có tương tác người dùng. Ví dụ vi rút hoặc các phần mềm độc hại cần tương tác người dùng để lây lan, như sao chép các file qua thẻ nhớ USB, mở email đính kèm, thực thi mã độc,... Các lỗ hổng loại quan trọng cũng cần được khắc phục càng sớm càng tốt.

Lỗ hổng bảo mật thuộc *cấp độ trung bình* là các lỗ hổng mà khi khai thác, kẻ tấn công phải ở trong cùng mạng cục bộ với hệ thống nạn nhân. Một ngữ cảnh khai thác lỗ hổng loại này là kẻ tấn công thực hiện việc bẫy nạn nhân sử dụng các kỹ thuật xã hội, như khai thác sự cả tin, tò mò và lòng tham của người dùng. Ngoài ra, việc khai thác lỗ hổng loại trung bình cũng chỉ cho phép kẻ tấn công có quyền truy nhập rất hạn chế vào hệ thống. Với lỗ hổng loại trung bình, cần xem xét khắc phục sớm nhất hoặc định kỳ để hạn chế ảnh hưởng.

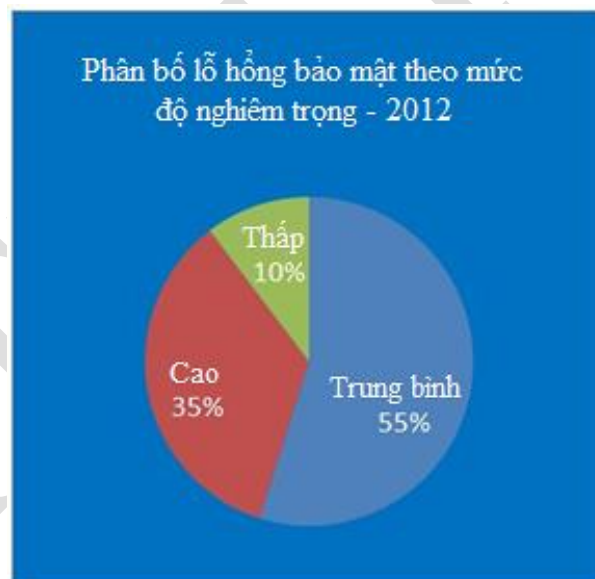
Loại cuối cùng là các lỗ hổng bảo mật thuộc *cấp độ thấp*. Các lỗ hổng loại này ít có ảnh hưởng đến hoạt động của tổ chức và chúng chỉ có thể bị khai thác khi kẻ tấn công có truy nhập cục bộ hoặc truy nhập vật lý trực tiếp vào hệ thống. Mặc dù có mức rủi ro thấp, các lỗ hổng loại này vẫn cần được xem xét khắc phục định kỳ để hạn chế ảnh hưởng.

2.1.2. Một số thống kê về lỗ hổng bảo mật

Theo số liệu thống kê từ Cơ sở dữ liệu lỗ hổng quốc gia Hoa Kỳ [6], trong năm 2012, phân bố lỗ hổng bảo mật được phát hiện trên các thành phần của hệ thống lần lượt là phần cứng – 4%, hệ điều hành – 10% và phần mềm ứng dụng – 86%, như minh họa trên Hình 2.2. Như vậy, có thể thấy các lỗ hổng bảo mật chủ yếu xuất hiện trong hệ thống phần mềm và phần lớn tồn tại trong các phần mềm ứng dụng.



Hình 2.2. Phân bố lỗ hổng bảo mật trong các thành phần của hệ thống [6]



Hình 2.3. Phân bố lỗ hổng bảo mật theo mức độ nghiêm trọng năm 2012 [6]

Theo mức độ nghiêm trọng của các lỗ hổng bảo mật hệ thống minh họa trên Hình 2.3, trong năm 2012 các lỗ hổng có mức độ nghiêm trọng cao (High) chiếm 35%, các lỗ hổng có mức độ nghiêm trọng trung bình (Medium) chiếm 55% và các lỗ hổng có mức độ nghiêm trọng thấp (Low) chỉ chiếm 10%. Theo thống kê rộng hơn trong giai đoạn 2005-2018 cho trên Hình 2.4 [6], các lỗ hổng có mức độ nghiêm trọng cao và mức độ nghiêm trọng trung bình luôn chiếm đa số. Như vậy, ta có thể thấy, đa số các lỗ hổng bảo mật có mức độ nghiêm trọng từ trung bình trở lên và cần được xem xét khắc phục càng sớm càng tốt.